



CYBERSECURITY INTRODUCTION AND OVERVIEW

Carlos A. Villalba Alvarado

AGENDA

- i. Introduction to Cybersecurity
- ii. Difference between Information Security and Cybersecurity
- iii. Cybersecurity Objectives
- iv. Governance, Risk Management, Compliance (GRC)
- v. Cybersecurity Domains
- vi. Related organizations and certifications

I. INTRODUCTION TO CYBERSECURITY



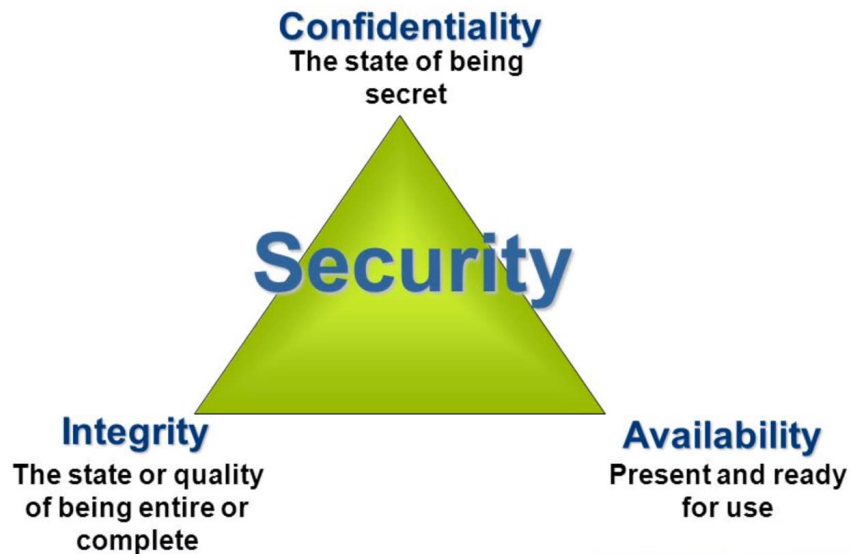
I. INTRODUCTION TO CYBERSECURITY



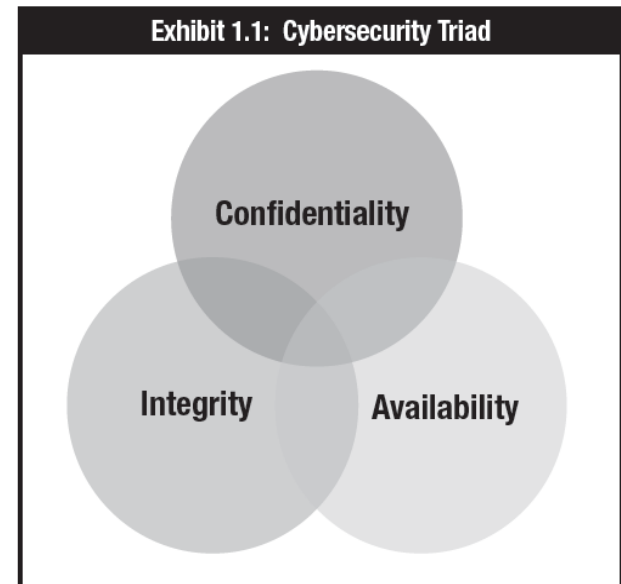
I. INTRODUCTION TO CYBERSECURITY

Three key concepts:

- Confidentiality: Protection from unauthorized access
- Integrity: Protection from unauthorized modification
- Availability: Protection from disruptions in Access. Reliable access to information and systems



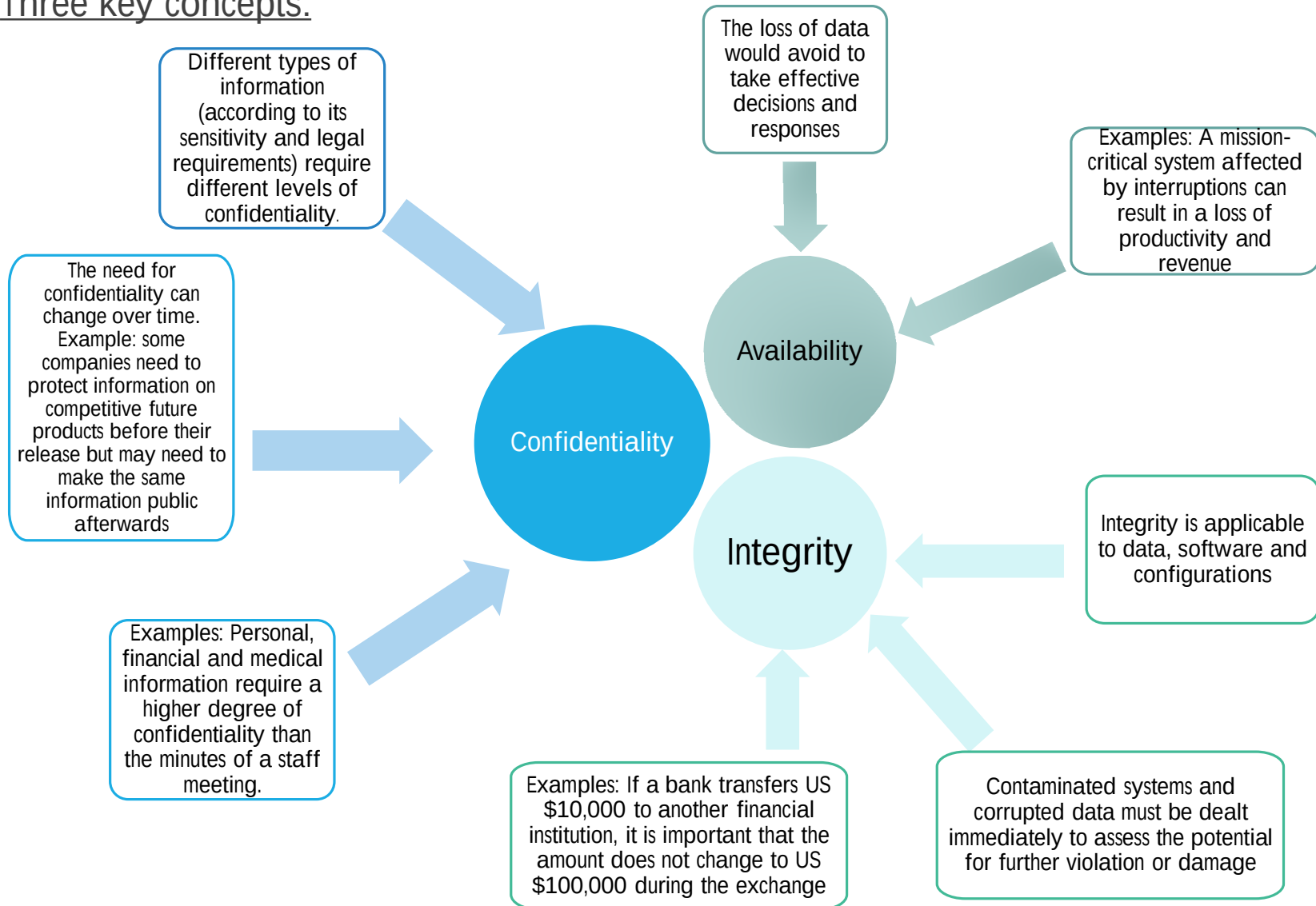
Source: <http://slideplayer.com/slide/8573727/>



Source: CSX Cybersecurity Fundamentals, Study Guide, 2nd Edition

I. INTRODUCTION TO CYBERSECURITY

Three key concepts:



I. INTRODUCTION TO CYBERSECURITY

Three key concepts:

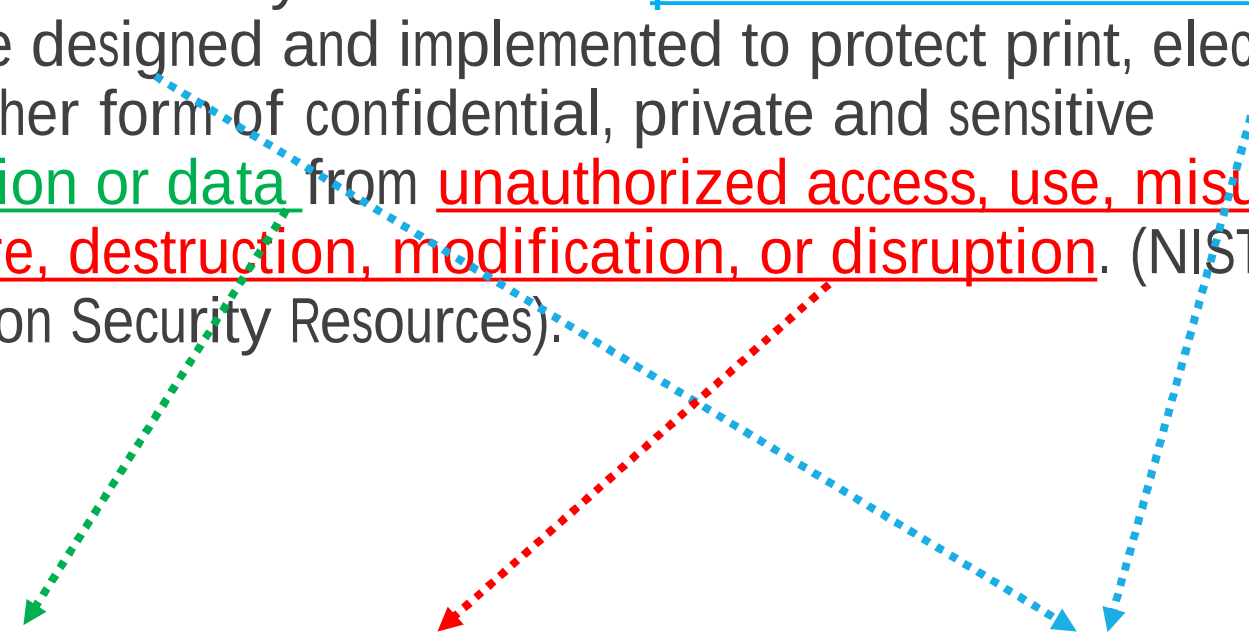
Identify a physical and digital data and indicate how are its requirements in terms of CID and how it is being protected (e.g. Physical Medical Prescription, Digital Grade Report).

Data/Asset #1	Requirements for each key concept (CID)	Explain how the asset is being protected in each key concept (CID)
Confidentiality (C)	...	...
Integrity (I)	...	...
Availability (D)	...	...

I. INTRODUCTION TO CYBERSECURITY

Definiton of Information Security:

Information Security refers to the processes and methodologies which are designed and implemented to protect print, electronic, or any other form of confidential, private and sensitive information or data from unauthorized access, use, misuse, disclosure, destruction, modification, or disruption. (NIST, Information Security Resources).



Data/Asset #1	Requirements for each key concept (CID)	Explain how the asset is being protected in each key concept (CID)
Confidentiality (C)	...	...
Integrity (I)	...	...
Availability (D)	...	...

I. INTRODUCTION TO CYBERSECURITY

Primer postulado en seguridad de la información:

La Seguridad es tan fuerte como el más débil de los mecanismos de apoyo que tenga implementado; así como una cadena es tan fuerte como el más débil de sus eslabones

"Las organizaciones gastan millones de dólares en firewalls y dispositivos de seguridad, pero tiran el dinero porque ninguna de estas medidas cubre el eslabón más débil de la cadena de seguridad: la gente que usa y administra los ordenadores".

Kevin Mitnick



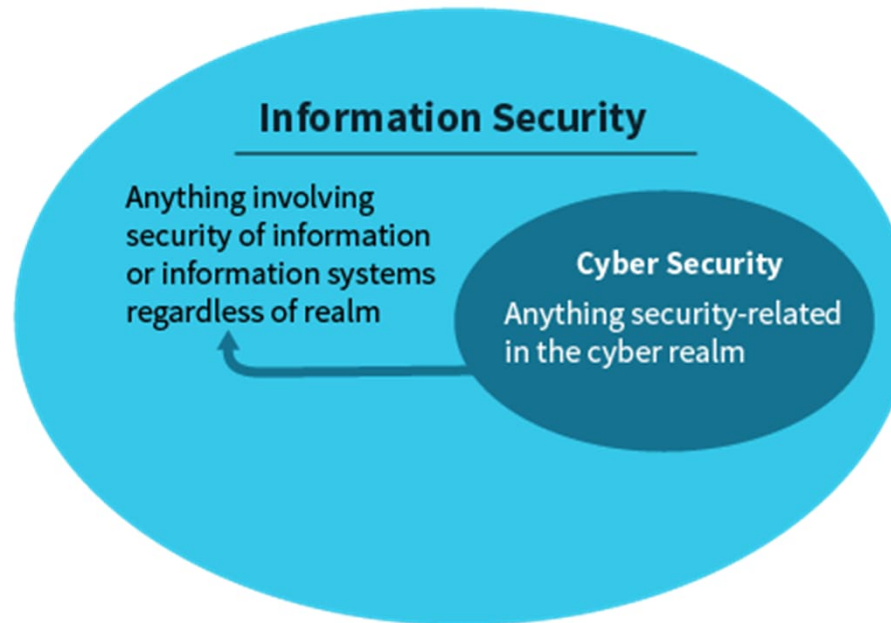
I. INTRODUCTION TO CYBERSECURITY

Definition of Cybersecurity:

Cybersecurity: Protection of information assets by addressing threats to **digital information** processed, stored and transported by internetworked information systems.

Realms:

- Physical security
- Natural hazards
- Personal mistakes
- Cyber Realm



Cyber Realm:

- Intentional attacks
- Breaches
- Incidents
- Impacts
- Offensive
- Adversary human behavior

Source:
Data protection vs. information security vs. cyber security. (n.d.). Retrieved October 14, 2017, from <https://www.legalfutures.co.uk/associate-news/data-protection-vs-information-security-vs-cyber-security>

Cybersecurity is included in information security

Cybersecurity does not include natural hazards, personal mistakes or physical security

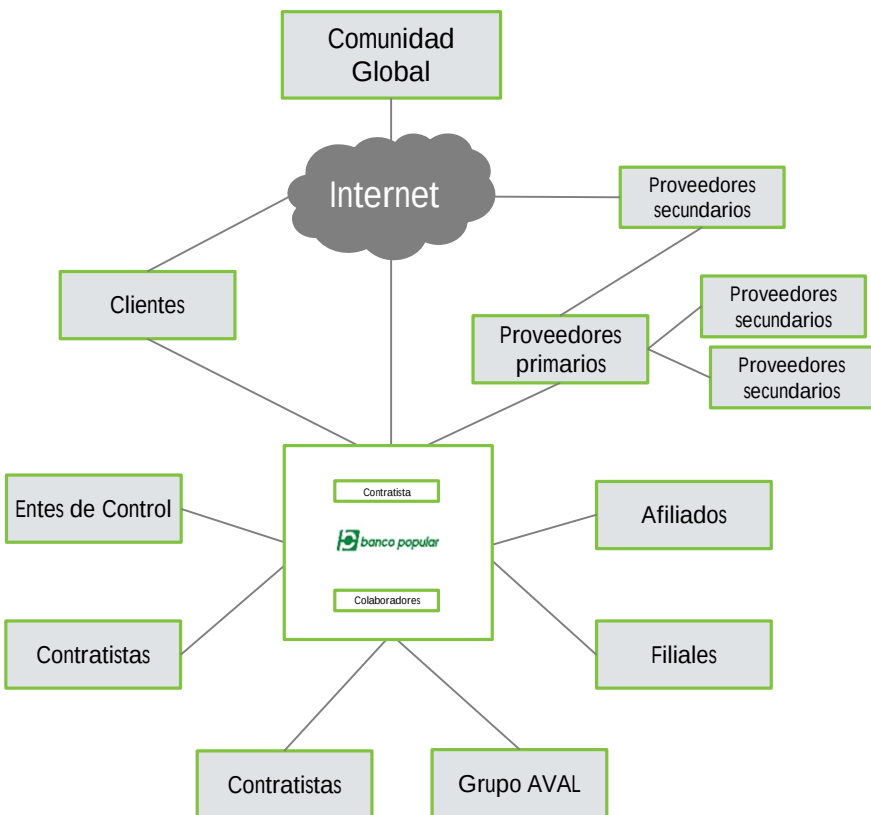
I. INTRODUCTION TO CYBERSECURITY

Definition of Cybersecurity:

Ciberspacio: Entorno complejo resultante de la interacción de personas, software y servicios en Internet a través de dispositivos tecnológicos conectados a dicha red, el cual no existe en ninguna forma física.¹

Seguridad de la Información: Es el conjunto de políticas, estrategias, metodologías, recursos, soluciones informáticas, prácticas y competencias para proteger, asegurar y preservar la confidencialidad, integridad y disponibilidad de la información de la entidad.¹

Ciberseguridad: Es el desarrollo de capacidades empresariales para defender y anticipar las amenazas cibernéticas con el fin de proteger y asegurar los datos, sistemas y aplicaciones en el ciberespacio que son esenciales para la operación de la entidad.¹



I. INTRODUCTION TO CYBERSECURITY

Insights encuesta global de seguridad 2016-17 - EY

US\$

US\$

US\$

18%

De los encuestados afirman que no pueden estimar el impacto financiero relacionado con los ciber incidentes.

56%

afirman que es improbable, que puedan detectar un ataque sofisticado.

41%

consideran la información de i + d en el top 5 de sus activos críticos.

Nivel de madurez de funciones críticas de ciberseguridad:

29% Seguridad del software

38% Monitoreo de seguridad

38% Gestión de incidentes

38% Gestión de identidades

52% Seguridad de red

63%

de la organizaciones declaran que su función de ciberseguridad no satisface las necesidades de la organización.

57%

De los encuestados respondieron que continuidad de negocio y recuperación ante desastres es su prioridad número uno en los próximos 12 meses.



48%

De las organizaciones afirman que no tienen un SOC.



30%

de los encuestados respondieron que su vulnerabilidad número uno son los empleados descuidados.

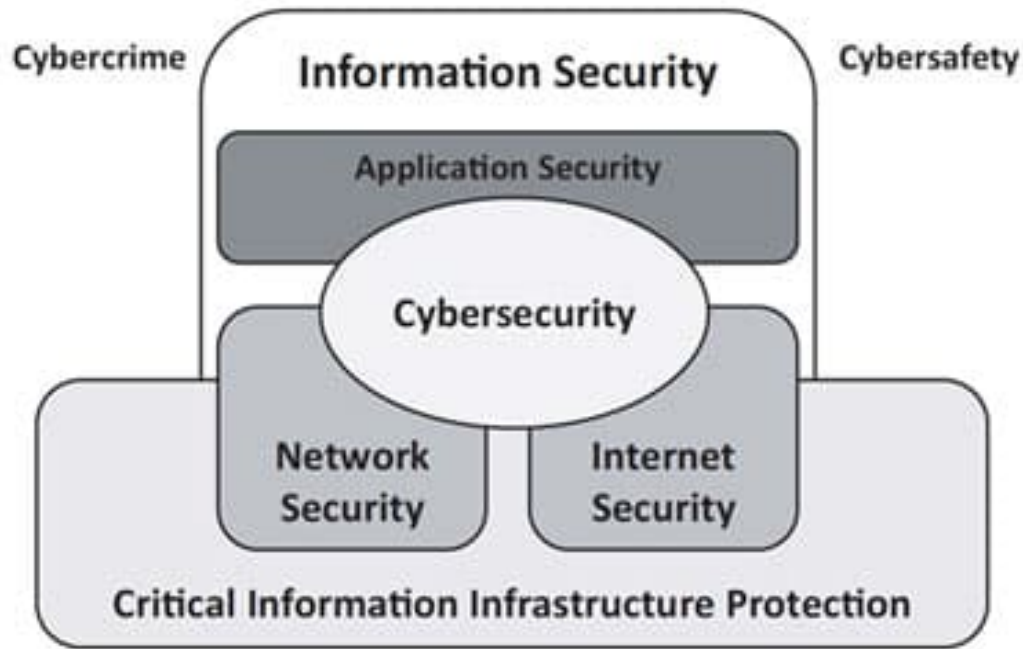
I. INTRODUCTION TO CYBERSECURITY

Another perspective...



I. INTRODUCTION TO CYBERSECURITY

Relation between cybersecurity and other security domains:



Source: ISO/IEC 27032:2012 – Guidelines for Cybersecurity

Not all critical infrastructure services impact cybersecurity

But, cybersecurity impacts negatively the availability and reliability of systems used by critical infrastructure providers

It is necessary a framework for information sharing and incident coordination, which involves all stakeholders (public, private, local, globally)

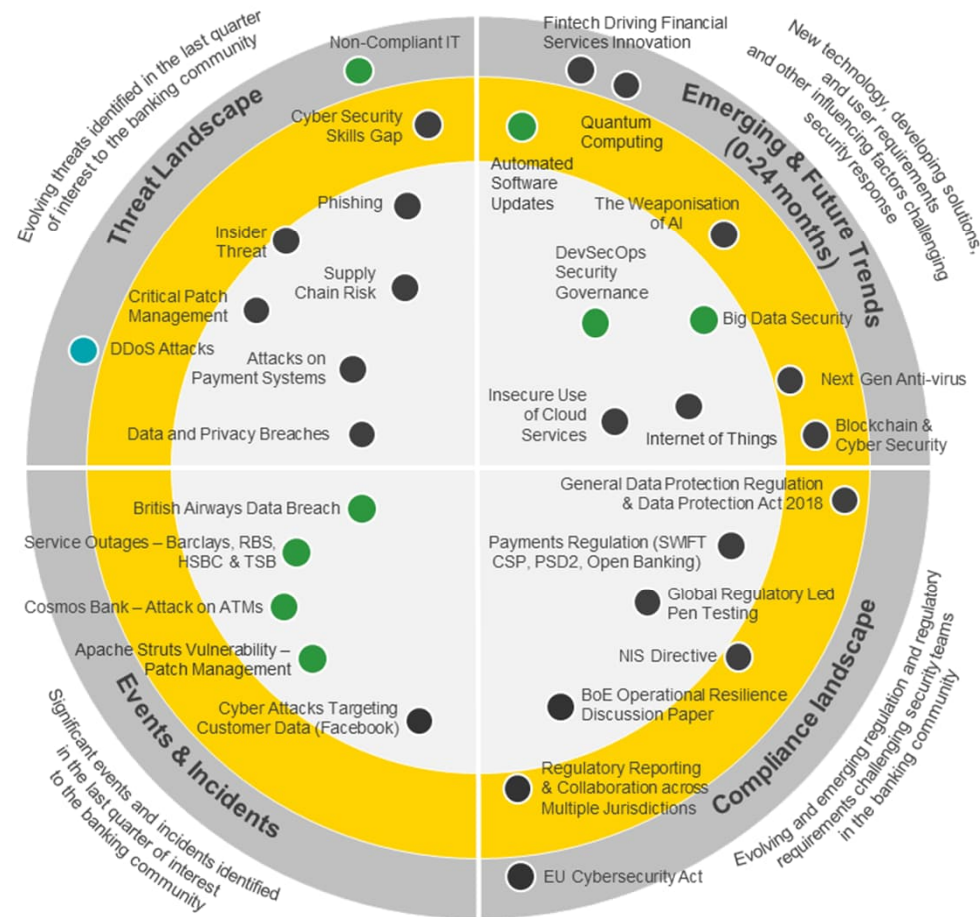
MISP (Malware Information Sharing Platform) could be a solution. Learn more at:
<https://www.misp-project.org/>

I. INTRODUCTION TO CYBERSECURITY

Give one example of a incident that be an Information Security Incident but NOT a Cybersecurity incident

I. INTRODUCTION TO CYBERSECURITY

The radar is a quarterly compilation of some of the key cyber security issues of potential interest to the industry.



I. INTRODUCTION TO CYBERSECURITY

Information Security vs Privacy

VARIABLES	SEGURIDAD DE LA INFORMACIÓN	PRIVACIDAD DE LA INFORMACIÓN
Fundamento	Es un proceso	Es un derecho
Finalidad	Protección de la información empresarial	Protección de la información personal
Características que se deben asegurar	Confidencialidad, integridad y disponibilidad	Anonimato, la imposibilidad para vincular, la imposibilidad para distinguir, la imposibilidad para rastrear y la pseudonimia
Responsable	Chief Information Security Officer (CISO)	Delegado de Protección de Datos personales (DPDP) / Chief Privacy Officer (CPO)
Foco	Centrado en los datos	Centrado en la persona
Aspectos claves que se deben cuidar	Protección de activos de información Foco en el valor para el negocio Asesor de confianza Cumplimiento de prácticas de protección de información	Garantías para el ejercicio del derecho de la privacidad Programa de privacidad Verificación del cumplimiento de prácticas de privacidad

Adaptación: J. Cano, Privacidad y seguridad de la información. Desafíos territoriales alrededor de la información (<http://insecurityit.blogspot.com.es/2014/02/privacidad-y-seguridad-de-la.html>)

www.escuelaing.edu.co

I. INTRODUCTION TO CYBERSECURITY

Give one example of student data that must be protected because of privacy of information (not information security)

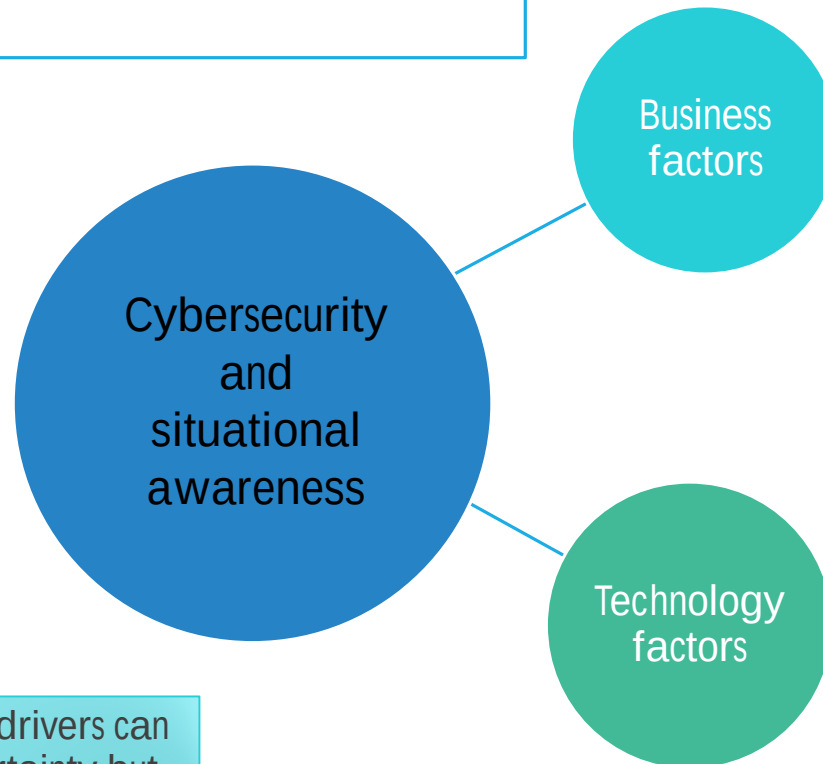
If you want to know your rights regarding the privacy of your data in @Escuelaing you may consult:

[POLÍTICA PARA EL TRATAMIENTO DE DATOS PERSONALES
ESCUELA COLOMBIANA DE INGENIERÍA JULIO GARAVITO](#)

Applicable law for Colombia: Ley 1581 de 2012

I. INTRODUCTION TO CYBERSECURITY

Importance of be aware about the situation of the organization



Business and technology drivers can not be predicted with certainty but they can be anticipated

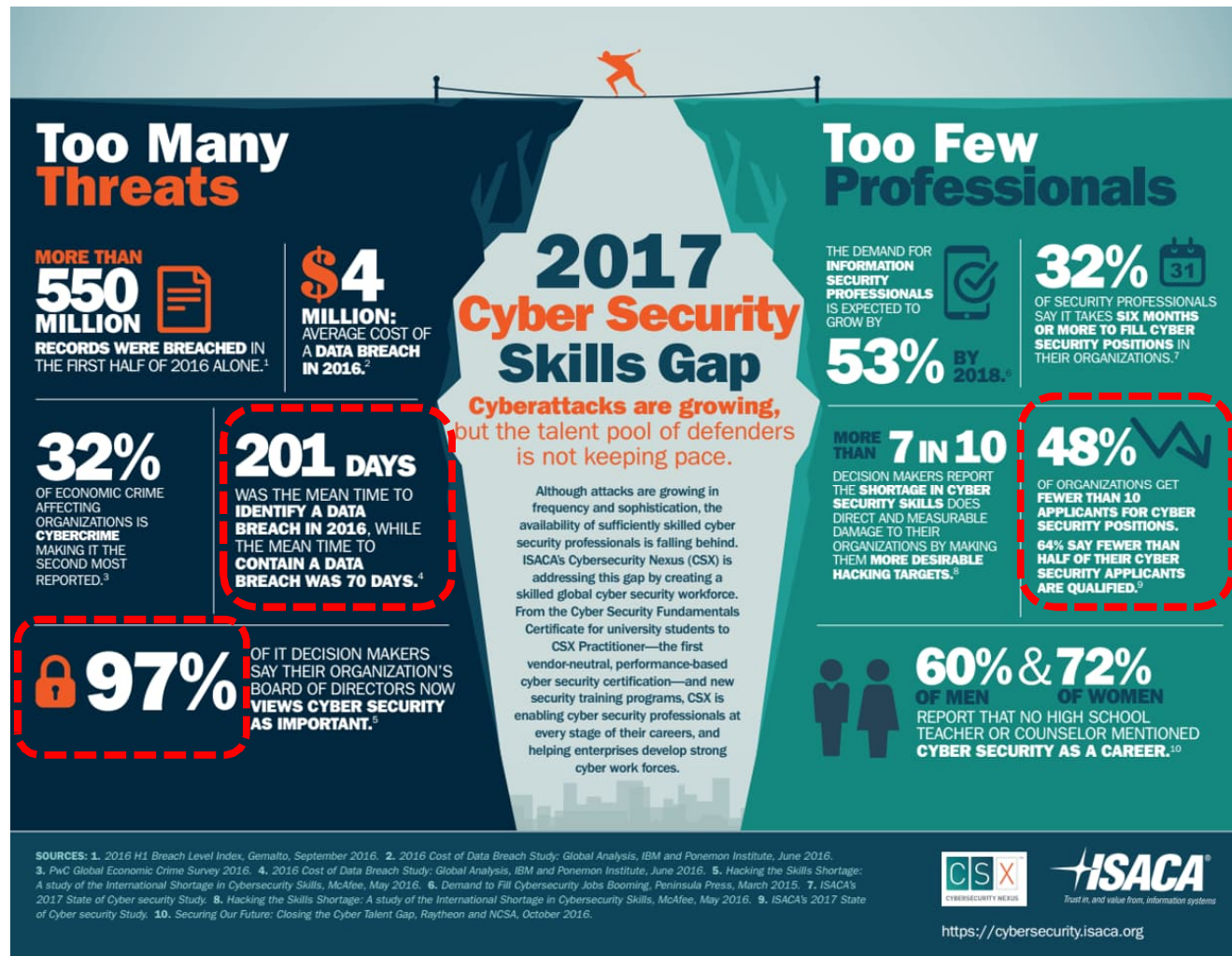
Anticipate business and technology drivers helps to react to changing business circumstances

1. Nature of business
2. Risk tolerance, risk appetite
3. Vision and strategy
4. Security profile
5. Industry trends for security
6. Mergers, acquisitions and partnerships
7. Consider type, frequency and resulting level of integration
8. Outsourcing services or providers
9. Compliance, regulations

1. Platforms and tools used
2. Applications
3. Infrastructure on premise, cloud or hybrid
4. Network connectivity (internal, third-party, public)
5. Level of IT complexity
6. Operational support for security
7. User community and capabilities
8. New or emerging security tools

I. INTRODUCTION TO CYBERSECURITY

Cybersecurity skills gap between reality and professional skills



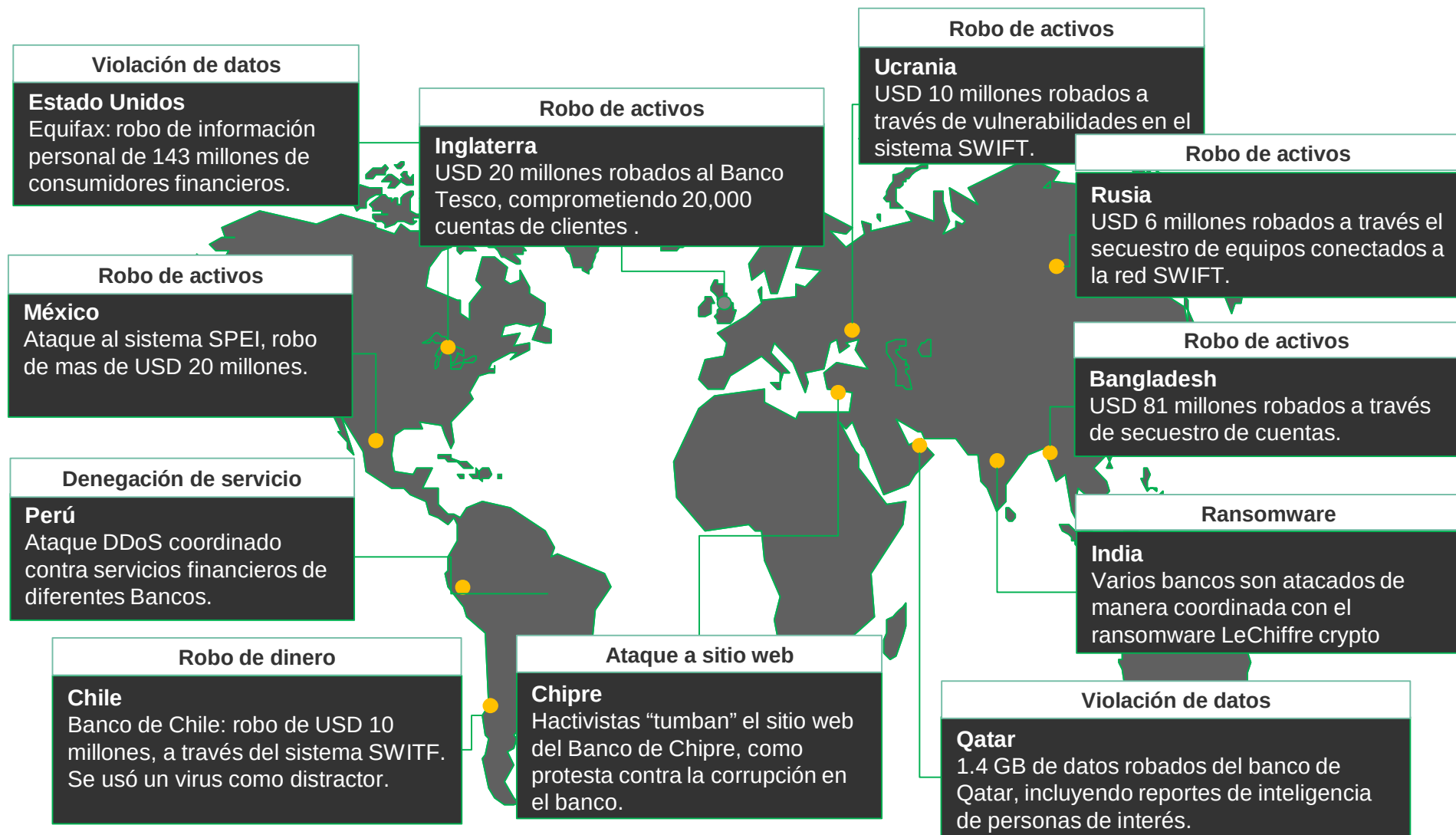
Organizations takes so many time identifying and containing (271 days)

IT decision makers are gaining support from C-Level to face security challenges

There is a lack of qualified info sec professionals

Certifications, e.g. CSX, is aimed to educate skilled cybersecurity workforce and reduce the gap

I. INTRODUCTION TO CYBERSECURITY



I. INTRODUCTION TO CYBERSECURITY

What have we learned until now?

1. Three Key concepts: CID
2. Information Security definition
3. Cybersecurity definition
4. Differences between Information security and Privacy
5. Situational awareness
6. Current landscape

AGENDA

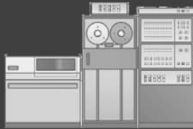
- i. Introduction to Cybersecurity
- ii. Difference between Information Security and Cybersecurity
- iii. Cybersecurity Objectives
- iv. Governance, Risk Management, Compliance (GRC)
- v. Cybersecurity Domains
- vi. Related organizations and certifications

II. IT EVOLUTION

La seguridad pertenece a un mundo físico. El reto es proteger los activos tangibles.



Aparición y evolución de los mainframes. Seguridad centrada en tarjetas perforadas



1900 - 1950

1950 - 1964

1964 - 1984

Circuitos integrados y aparición del microprocesador. Se empieza a hablar de seguridad de la información.



Redes e interconexión entre redes. Primeros virus de computadoras.



1984 - 1993

Internet se vuelve de dominio público e inicia el auge de los sitios web. Primeros ataques a través de internet.



Aumento exponencial de usuarios de internet. Ataques dirigidos y con motivación contras las redes corporativas.



1993 - 2000

2000 - 2010

Estar conectado es el nuevo orden natural. El reto ahora es en el ciber espacio.



2010 . . .

II. DIFFERENCE BETWEEN INFORMATION SECURITY AND CYBERSECURITY

Information security deals with information regardless of its format: mental, physical, digital, verbal or visual



Cybersecurity deals just with digital assets (network hardware, software, and information).

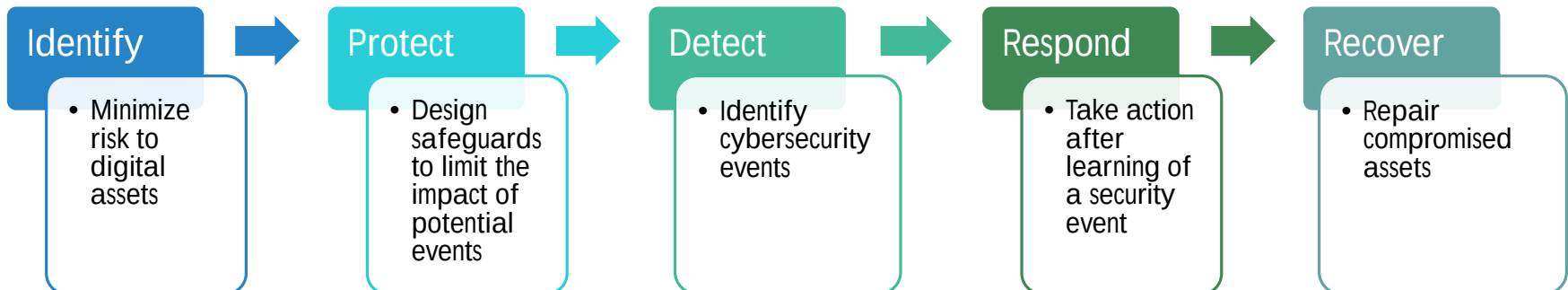


NIST Cybersecurity Framework defines five key functions to protect digital assets



How to protect digital assets?

Key **5 functions** to protect digital assets:



AGENDA

- i. Introduction to Cybersecurity
- ii. Difference between Information Security and Cybersecurity
- iii. Cybersecurity Objectives
- iv. Governance, Risk Management, Compliance (GRC)
- v. Cybersecurity Domains
- vi. Related organizations and certifications

III. CYBERSECURITY OBJECTIVES

Lets remember the three key concepts:

- Confidentiality: Protection from unauthorized access
- Integrity: Protection from unauthorized modification
- Availability: Protection from disruptions in access

And another key one:

- Non repudiation: It assures that the data's integrity has been protected and that the party sending or receiving it cannot deny or repudiate that they sent or received it.



How to achieve this?



Transactional logs

Digital signatures

III. CYBERSECURITY OBJECTIVES

Taller
30 minutos

Exhibit 1.4: Confidentiality, Integrity and Availability Model and Related Impacts

Requirement	Impact and Potential Consequences	Methods of Control
Confidentiality: the protection of information from unauthorized disclosure	Loss of confidentiality can result in the following consequences: 	Confidentiality can be preserved using the following methods: 
Integrity: the accuracy and completeness of information in accordance with business values and expectations	Loss of integrity can result in the following consequences: 	Integrity can be preserved using the following methods: 
Availability: the ability to access information and resources required by the business process following consequences:	Loss of availability can result in the following consequences: 	Availability can be preserved using the following methods: 

III. CYBERSECURITY OBJECTIVES

Exhibit 1.4: Confidentiality, Integrity and Availability Model and Related Impacts

Requirement	Impact and Potential Consequences	Methods of Control
Confidentiality: the protection of information from unauthorized disclosure	Loss of confidentiality can result in the following consequences: • Disclosure of information protected by privacy laws • Loss of public confidence • Loss of competitive advantage • Legal action against the enterprise • Interference with national security	Confidentiality can be preserved using the following methods: • Access Controls • File Permissions • Encryption
Integrity: the accuracy and completeness of information in accordance with business values and expectations	Loss of integrity can result in the following consequences: • Inaccuracy • Erroneous decisions • Fraud	Integrity can be preserved using the following methods: • Access controls • Logging • Digital Signatures • Hashes • Encryptions
Availability: the ability to access information and resources required by the business process following consequences:	Loss of availability can result in the following consequences: • Loss of functionality and operational effectiveness • Loss of productive time • Interference with enterprise's Objectives	Availability can be preserved using the following methods: • Redundancy • Backups • Access Controls

III. CYBERSECURITY OBJECTIVES

There are more...

We've just seen these ones!



AGENDA

- i. Introduction to Cybersecurity
- ii. Difference between Information Security and Cybersecurity
- iii. Cybersecurity Objectives
- iv. Governance, Risk Management, Compliance (GRC)
- v. Cybersecurity Domains
- vi. Related organizations and certifications

IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Even if every organization is different, but all organizations share the responsibility to protect assets and operations (also IT)

How to?

Governance, Risk Management, Compliance (GRC)

- Provide strategic direction
- Ensure that objectives are achieved
- Ascertain whether risk is being managed appropriately
- Verify that the organization's resources are being used responsibly

Governance

Risk management

- Manages risk to acceptable levels.
- It requires the implementation of controls to manage and mitigate risk
- It includes many kind of risks: financial and investment risk, physical risk and cyberrisk

- Demonstrate adherence to mandated requirements defined by laws and regulations
- Adherence to contractual obligations and internal policies

Compliance

Which role is able for each component of GRC?

IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Information Security Roles

- Review and verify protection levels are appropriate
- They must set a good example
- Define penalties for non compliance

- They implement Governance, approve policies, monitor metrics, trend analysis, high-level results of risk assessments and BIA (business impact analysis)
- Must be aware of the organization's information assets

- Positions: Security architects, administrators, digital forensics and network security specialists
- Design, implement and manage processes and technical controls

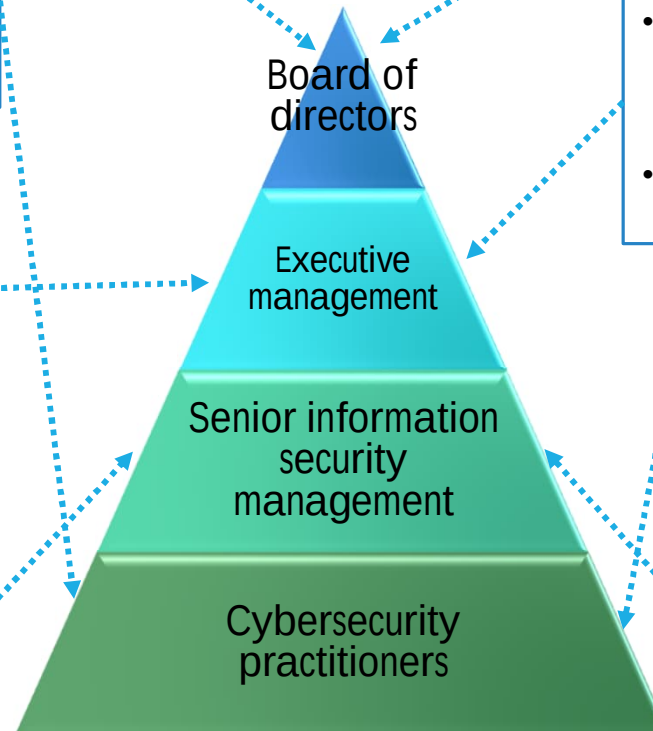
- Ensuring that functions, resources, and supporting infrastructure are available to fulfill directives of the board and compliance
- Define the Information Security Program

- CISO (Chief Information Security Officer) or cybersecurity manager serve here as advisors: present options and key information
- They include risk management in key business activities and decisions

- Respond to events and incidents
- Follow direction, policies, guidelines, mandates and regulations defined in the Information Security Program

- Positions: CISO (Chief Information Security Officer), CSO (Chief Security Officer) or cybersecurity manager
- Developing the security strategy
- Coordinating with business process owners for ongoing alignment

- Ensuring that risk and business impact assessments are conducted
- Developing risk mitigation strategies
- Enforcing policy and regulatory compliance
- Implementing monitoring and metrics
- Managing cybersecurity incidents



IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Let's integrate concepts...

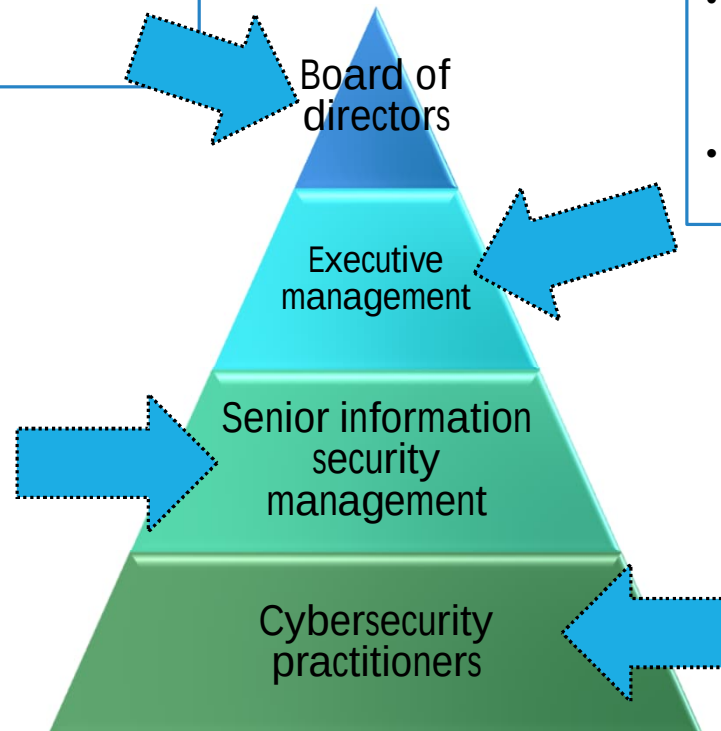
Information Security Roles

- They implement Governance, approve policies, monitor metrics, trend analysis, high-level results of risk assessments and BIA (business impact analysis)
- Must be aware of the organization's information assets
- Review and verify protection levels are appropriate
- They must set a good example
- Define penalties for non compliance

- Ensuring that functions, resources, and supporting infrastructure are available to fulfill directives of the board and compliance
- Define the Information Security Program
- CISO (Chief Information Security Officer) or cybersecurity manager serve as advisors: present options and key information
- They include risk management in key business activities and decisions

- Positions: CISO (Chief Information Security Officer), CSO (Chief Security Officer) or cybersecurity manager are located
- Developing the security strategy
- Coordinating with business process owners for ongoing alignment
- Ensuring that risk and business impact assessments are conducted
- Developing risk mitigation strategies
- Enforcing policy and regulatory compliance
- Implementing monitoring and metrics
- Managing cybersecurity incidents

- Positions: Security architects, administrators, digital forensics and network security specialists
- Design, implement and manage processes and technical controls
- Respond to events and incidents
- Follow direction, policies, guidelines, mandates and regulations defined in the Information Security Program



IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Even if every organization is different, but all organizations share the responsibility to protect assets and operations (also IT)

How to?

Governance, Risk Management, Compliance (GRC)

- Provide strategic direction
- Ensure that objectives are achieved
- Ascertain whether risk is being managed appropriately
- Verify that the organization's resources are being used responsibly

Governance

Risk management

- Manages risk to acceptable levels.
- It requires the implementation of controls to manage and mitigate risk
- It includes many kind of risks: financial and investment risk, physical risk and cyberrisk

- Demonstrate adherence to mandated requirements defined by laws and regulations
- Adherence to contractual obligations and internal policies

Compliance

• Directors

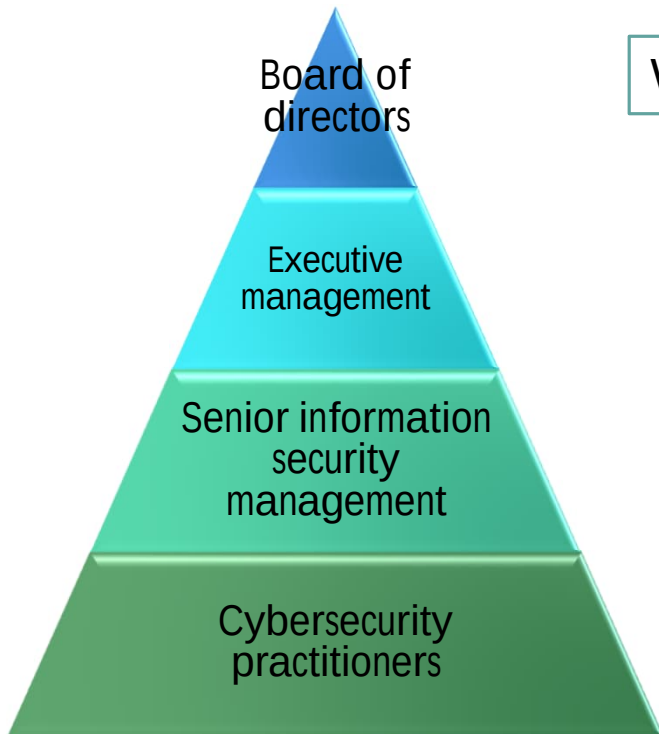
- Executive management
- Senior information security management

- Directors
- Executive management
- Senior information security
- Cybersecurity practitioners

Which role is able for each component of GRC?

IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Information Security Roles



Which other actor lacks?

R/ The Attacker



IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Cracker



Phreak



IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Quién?

Ladrones
 Competidores
 Gobiernos
Organizaciones
Políticas
 Hackers
 Empleados
 Grupos
 Expertos en Seguridad
 Público en General

Por qué ?

Ganancias
 Financieras
 Espionaje Industrial /
 Comercial / Nacional
 Fama Pública /
 Privada
 Venganza
 Ignorancia
 Ideales
 Aprendizaje
 Curiosidad

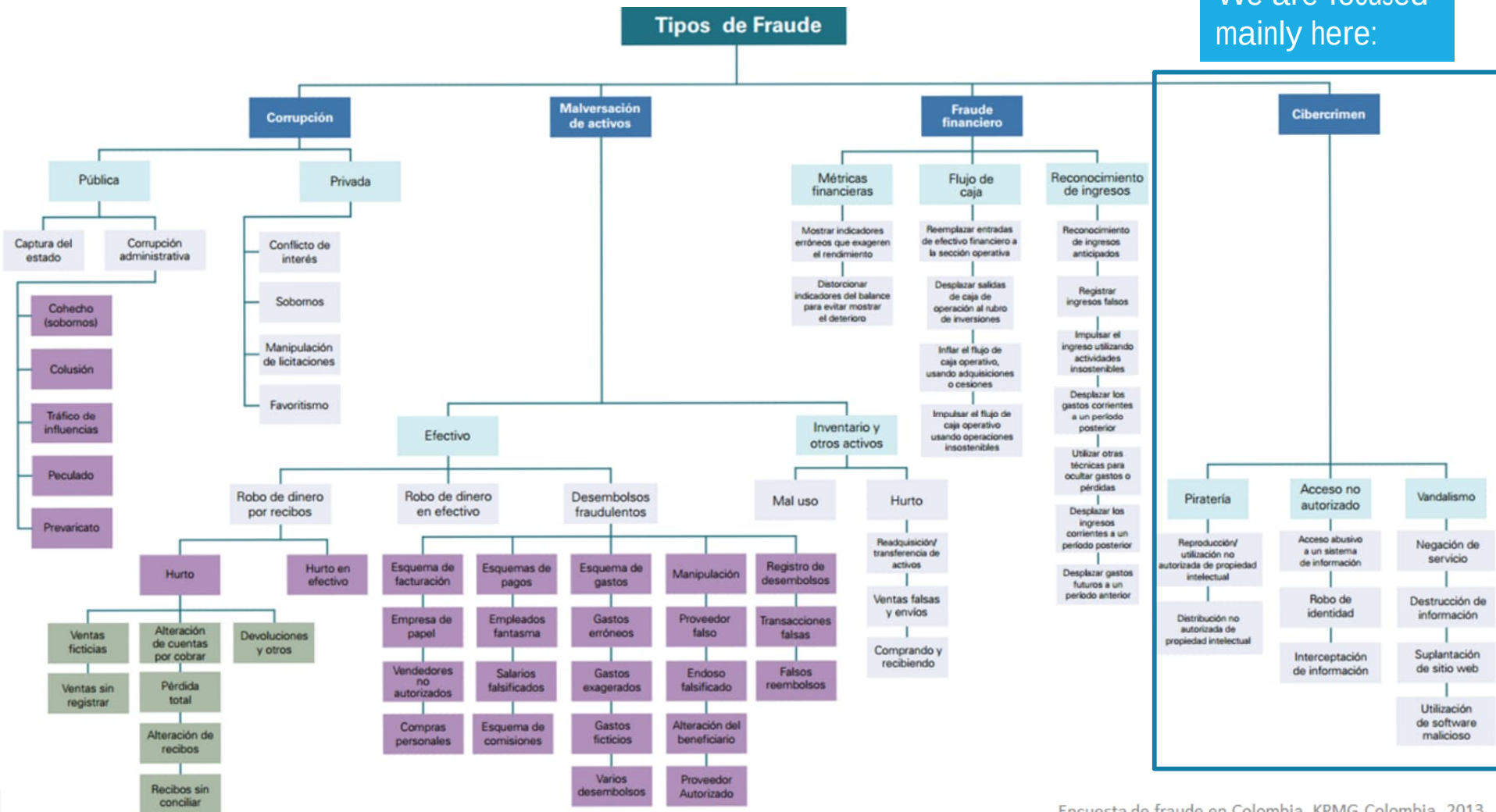
Cómo ?

Intercepción
 Enmascaramiento
 Eavesdropping
 Retardo de Mensajes/
 Negación de Servicio
 Réplicas de
 Paquetes/Mensajes
 Modificación de
 Mensajes
 Virus

IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

Example of Frauds:

We are focused
mainly here:



IV. GOVERNANCE, RISK MANAGEMENT, COMPLIANCE (GRC)

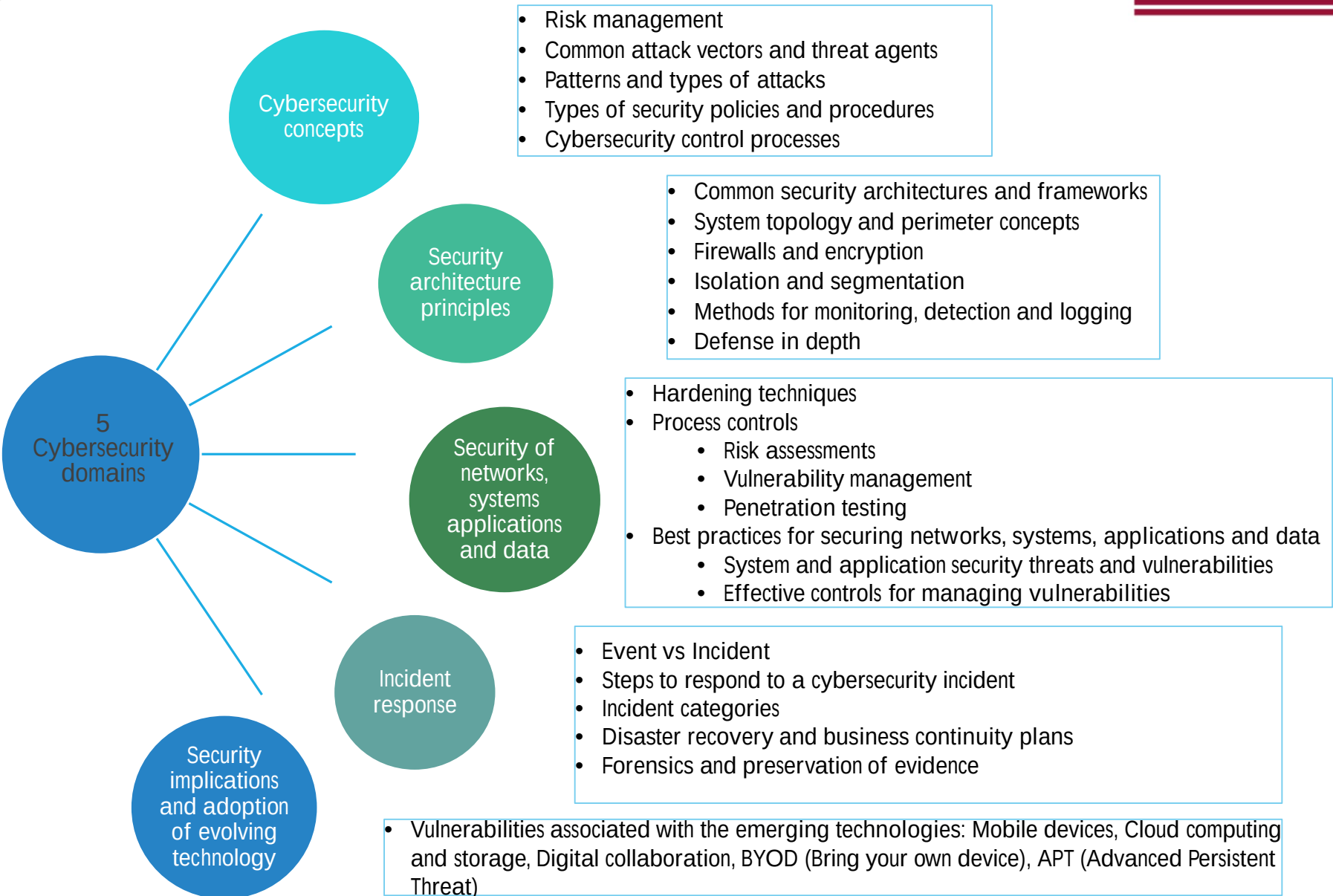
What have we learned until now?

1. Difference Information security and Cybersecurity
2. Many Cybersecurity objectives (not just CID)
3. Information Security Roles
4. GRC (Governance, Risk Management, Compliance)

AGENDA

- i. Introduction to Cybersecurity
- ii. Difference between Information Security and Cybersecurity
- iii. Cybersecurity Objectives
- iv. Governance, Risk Management, Compliance (GRC)
- v. Cybersecurity Domains
- vi. Related organizations and certifications

V. CYBERSECURITY DOMAINS



AGENDA

- i. Introduction to Cybersecurity
- ii. Difference between Information Security and Cybersecurity
- iii. Cybersecurity Objectives
- iv. Governance, Risk Management, Compliance (GRC)
- v. Cybersecurity Domains
- vi. Related organizations and certifications

VI. RELATED ORGANIZATIONS AND CERTIFICATIONS

Important organizations supporting the cybersecurity (Internationally)

- CERT (Computer Emergency Response Team)
- Carnegie Mellon University
- CSI (Computer Security Institute)
- ICSA (International Computer Security Association)
- NCSA (National Computer Security Association)
- NIST (National Institute of Standards and Technology)
- NSA (National Security Agency)
- BSI (British Standard Institute)
- USCYBERCOM (Cibercomando de USA)
- ISO (International Standard Organization)
- GCA (Global Cibersecurity Agency)

Important organizations supporting the cybersecurity (Nationally)

- Política de seguridad democrática
- CONPES de seguridad
- COLCERT (Centro de respuesta de emergencia de ciberdefensa de Colombia)
- Comando Conjunto Cibernético del Comando General de las Fuerzas Militares
- Centro Cibernético Policial

V. RELATED ORGANIZATIONS AND CERTIFICATIONS

15 Highest-Paying Tech Jobs for 2020 (Information Week)

1. Chief Information Officer. 202500
2. Chief Technology Officer. 175.000
3. Chief Security Officer. 170.000
4. Vice President of Information Technology. 163.000
5. Big Data Engineer. 150.000
6. Director of Technology. 141.000
7. Mobile Application Developer. 141.000
8. Director (Consulting & Systems Integration. 139.000
9. Information Systems Security Manager. 137.000
10. Network Architect. 134.000
11. Applications Architect. 132.000
12. Data Architect. 130.000
13. Senior IT Auditor. 127.000
14. Database Manager. 127.000
15. Application Development Manager. 125.000

V. RELATED ORGANIZATIONS AND CERTIFICATIONS

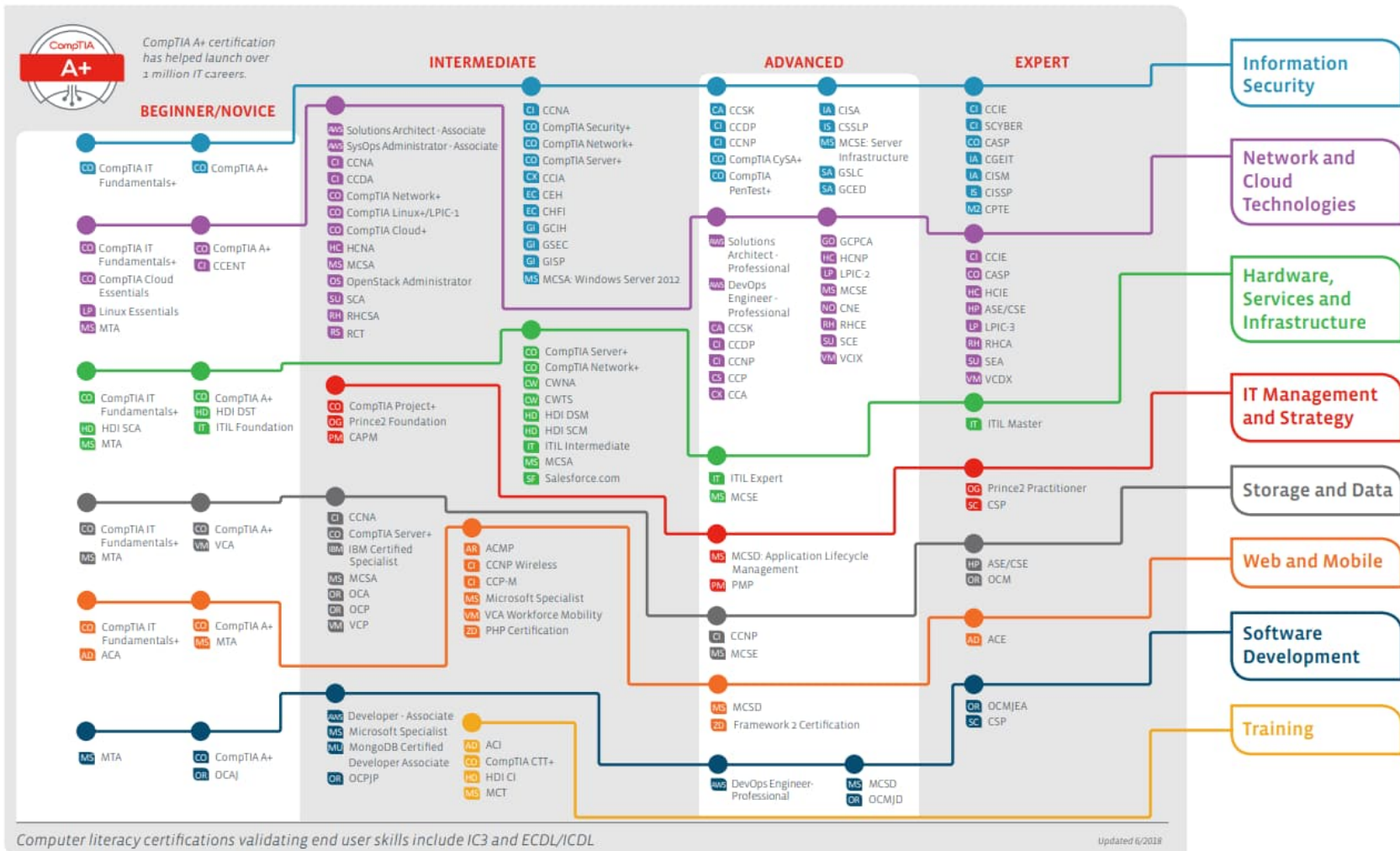
Most Valuable IT Certifications, 2018 (Source: Global Knowledge Study, 15 Top-Paying Certifications for 2018)	
Certification	Annual Salary
Certified in the Governance of Enterprise IT (CGEIT)	\$ 121,363
AWS Certified Solutions Architect – Associate	\$ 121,292
Project Management Professional (PMP®)	\$ 114,473
AWS Certified Developer – Associate	\$ 114,148
Certified Information Systems Security Professional (CISSP)	\$ 111,475
Certified in Risk and Information Systems Control (CRISC)	\$ 111,049
Certified Information Security Manager (CISM)	\$ 108,043
Certified ScrumMaster	\$ 106,938
Certified Ethical Hacker (CEH)	\$ 106,375
Six Sigma Green Belt	\$ 104,099
Citrix Certified Professional – Virtualization (CCP-V)	\$ 103,424
Microsoft Certified Solutions Expert (MCSE) – Server Infrastructure	\$ 100,656
Certified Information Systems Auditor (CISA)	\$ 99,684
Cisco Certified Networking Professional (CCNP) Routing and Switching	\$ 99,402
Citrix Certified Associate – Networking (CCA-N)	\$ 99,217

V. RELATED ORGANIZATIONS AND CERTIFICATIONS

IT Certification Roadmap

Explore the possibilities with the CompTIA Interactive IT Roadmap at:
CompTIA.org/CertsRoadmap

Certifications validate expertise in your chosen career.



<https://certification.comptia.org/docs/default-source/downloadablefiles/it-certification-roadmap.pdf>

<https://certification.comptia.org/why-certify/roadmap>

I. INTRODUCTION TO CYBERSECURITY



ADDITIONAL REQUIREMENTS

1. Lectura:

An integrated vision to manage cyber risk



GRACIAS